```
# Metabase RCE Honeypot EC2 — non-public, SSH + SSM access exercise

## Problem

We want a honeypot host running a **genuinely vulnerable Metabase** so it scans
positive for the Metabase nuclei templates, including the pre-auth RCE
**[CVE-2023-38646](https://github.com/advisories/GHSA-jg32-8h6w-x7vg "CVE-2023-38646")**. The catch:
the Metabase service must **not** be reachable
from the internet. This doubles as onboarding — you'll learn to reach EC2 safely
over SSH and via **SSM Session Manager**, and prove the box is non-public.

This is a defensive honeypot in our own account; the vulnerable service stays
firewalled off.

## Goal

A new Pulumi stack (follow conventions,
) that stands up an EC2 instance running a vulnerable Metabase,
locked down so only you can reach the box — and only over SSH/SSM, never the
Metabase service itself.`infra/metabase``infra/CONTRIBUTING.md``ap-northeast-1`

## Requirements

- Metabase runs a version genuinely vulnerable to **[CVE-2023-38646]
(https://github.com/advisories/GHSA-jg32-8h6w-x7vg "CVE-2023-38646")** (figure out
    which tag, and what state it has to be left in for the template to keep firing).
- The Metabase service is **not** publicly reachable — by network policy _and_ how
    the service binds. Think about why one control alone isn't enough.
- SSH (port 22) is reachable only from your own IP, nothing wider.
- Session Manager works as a second, keyless way in.

## Acceptance Criteria

- nuclei run from **your laptop** against the public IP finds **nothing**.
- nuclei run from **the box itself** fires the Metabase detection template(s) and
    .`CVE-2023-38646`
- SSH succeeds only from your IP; SSM Session Manager works with no inbound rule.
- `pulumi up` / `pulumi destroy` are clean and idempotent.

## What to write up

Short notes in the stack README covering: how you connected over SSH vs SSM, the
two nuclei results (laptop vs box) that prove it's non-public-but-vulnerable, and
why the box can't be reached from the internet.

## Out of Scope

- Public DNS, TLS/CloudFront — the service is intentionally non-public.
- Attack logging / alerting / live-traffic capture — possible follow-up.
- Actually exploiting the RCE beyond confirming nuclei fires.

## Notes

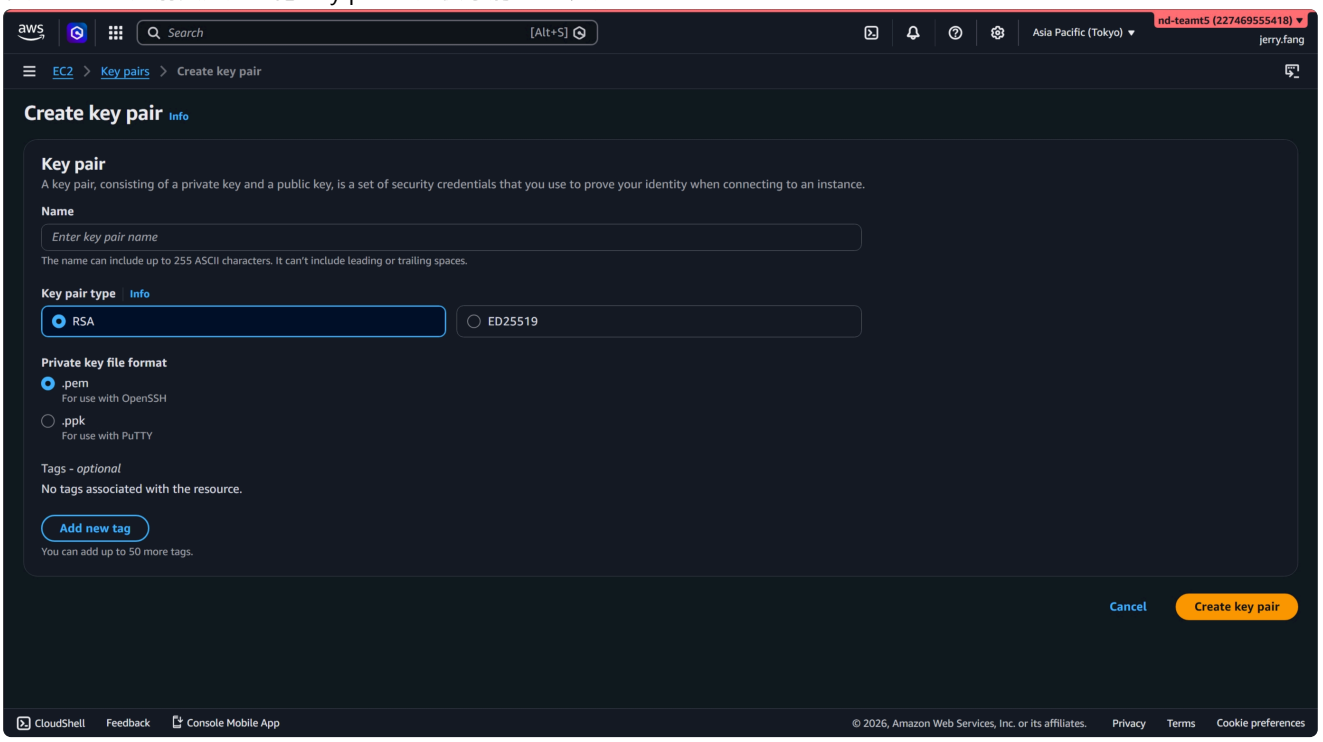
- Never open port 22 wider than your own IP, and never expose the Metabase port.
- Tear the stack down when you're done.
```

Test

想要先建一個 ec2 看一下有哪些設定

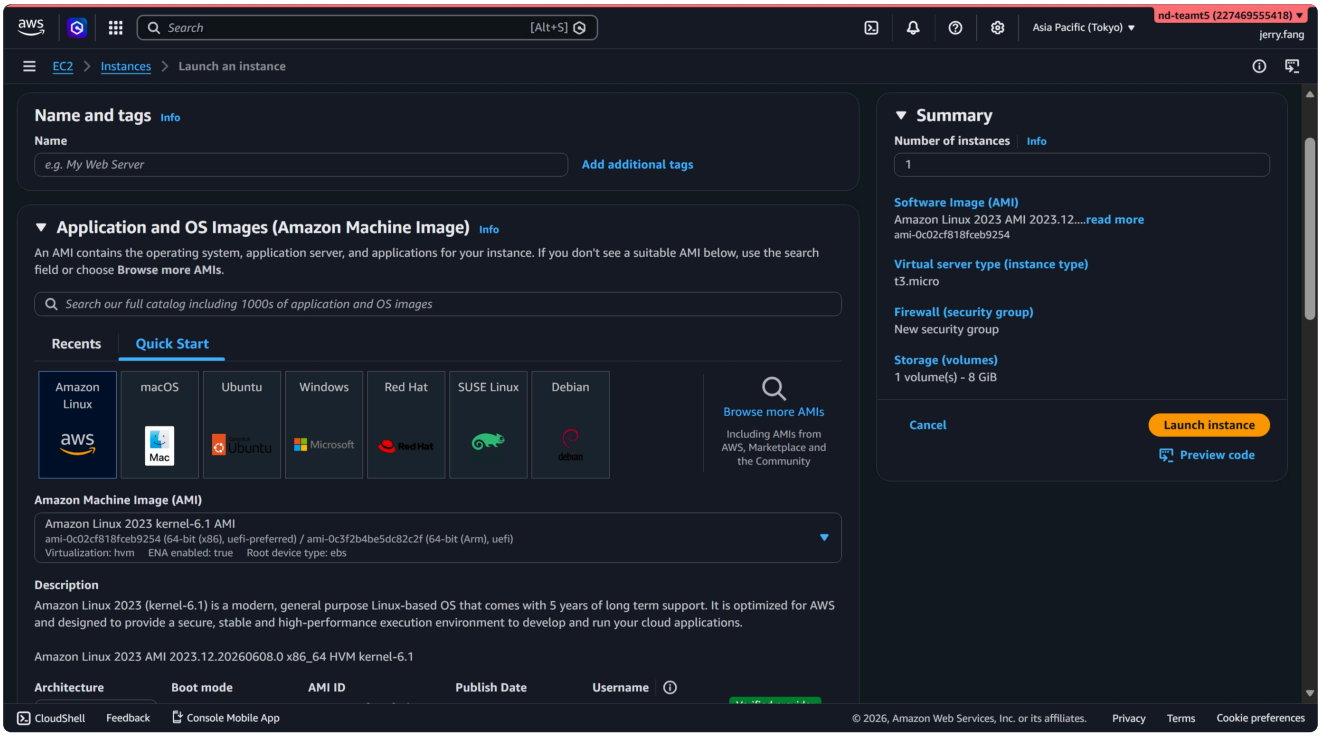
Key pair

在建立 EC2 之前要先建一把 key pair，之後才能 SSH 連進 EC2。

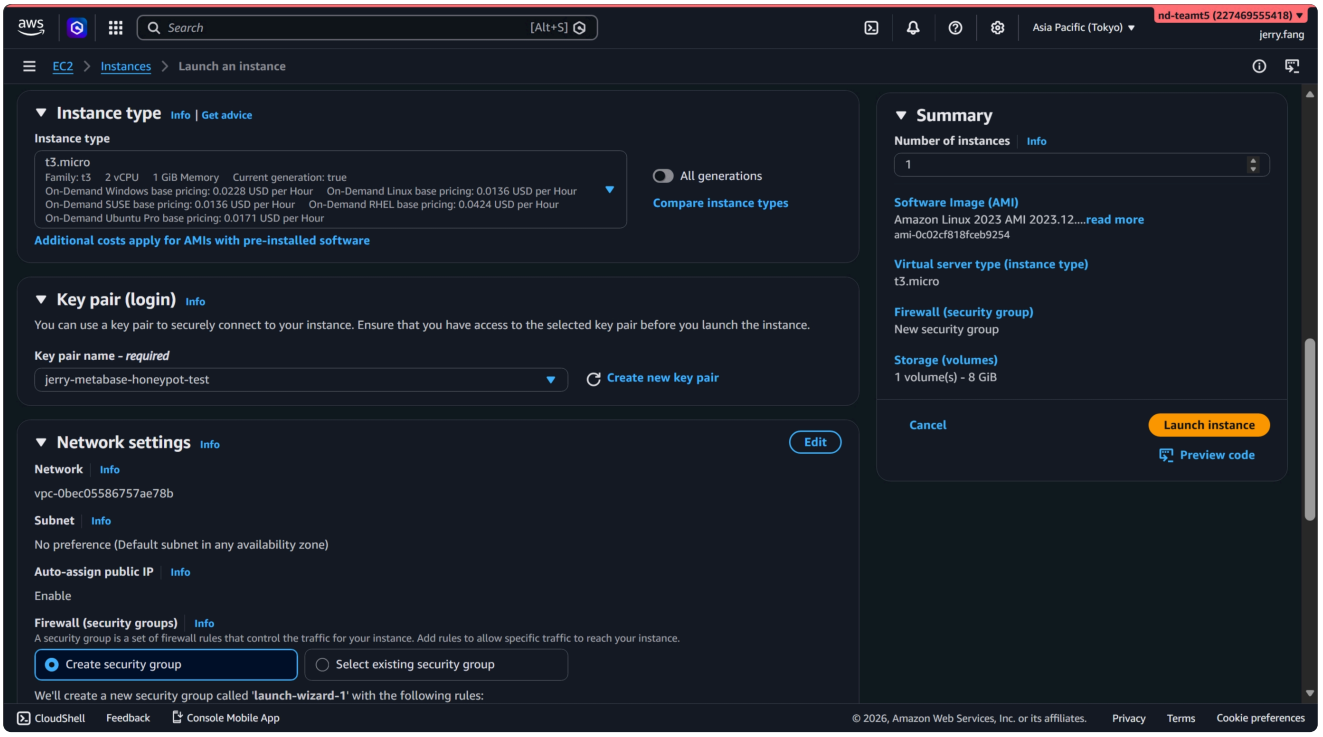


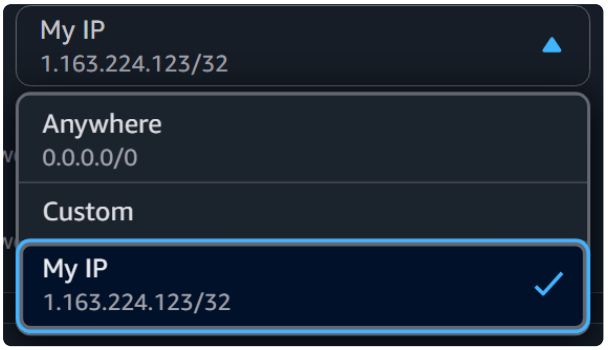
EC2

建立 ec2

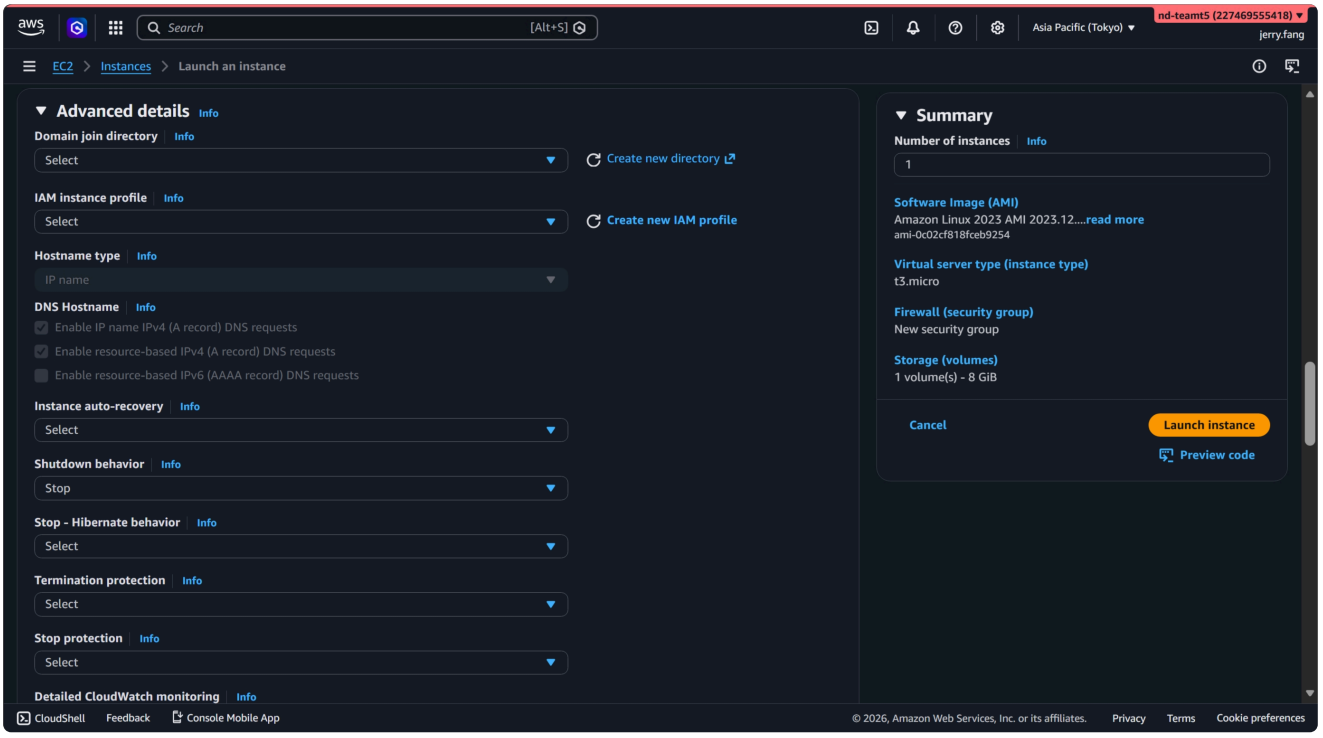


因為只是想 SSH 進去，所以先設好 key，然後網路（SG）的來源要設成 my ip，不然用預設的 0.0.0.0 等於全世界都可以連進來

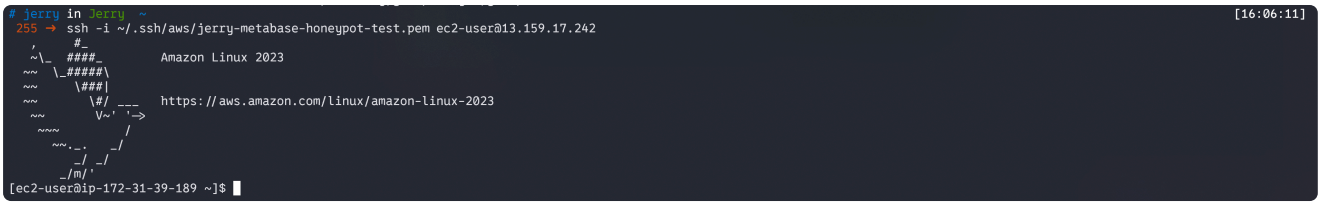




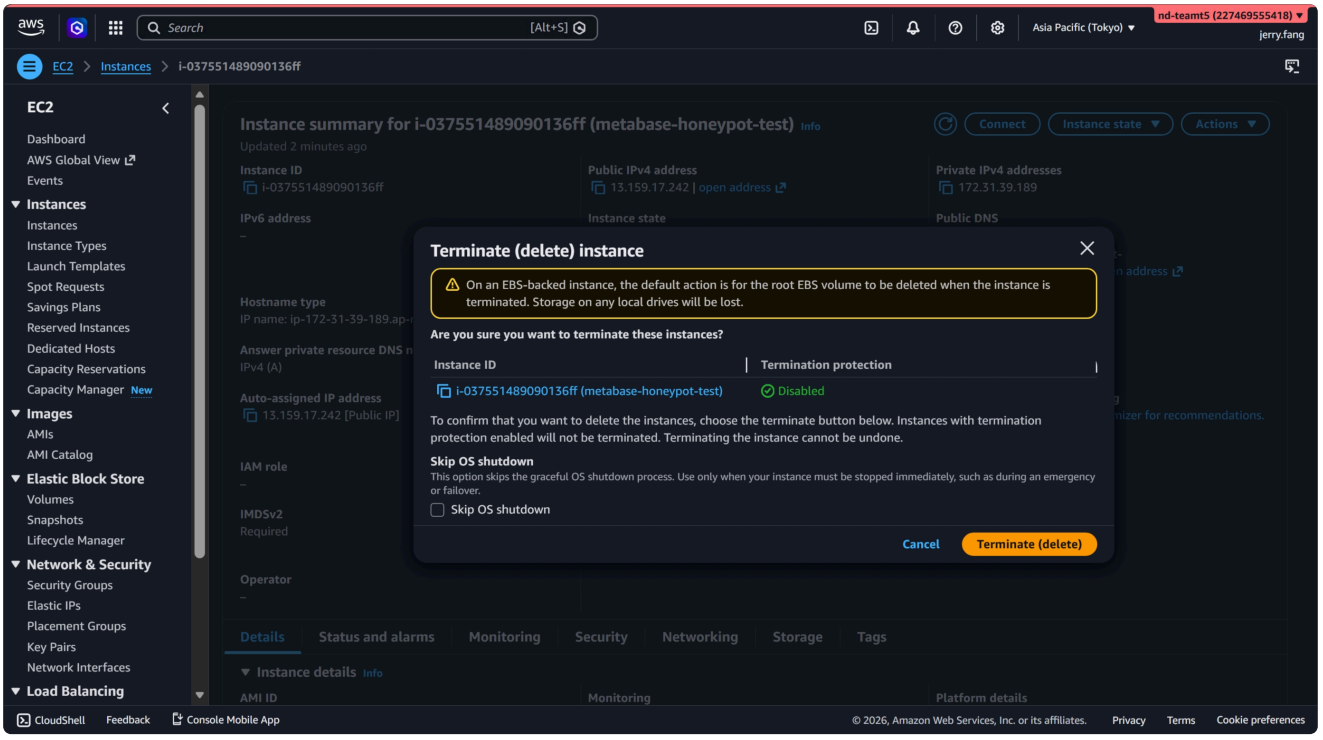
在進階設定的地方有看到 IAM instance profile，這應該是拿來給 EC2 權限用的，如果未來要用 SSM Session Manager 應該就會需要它



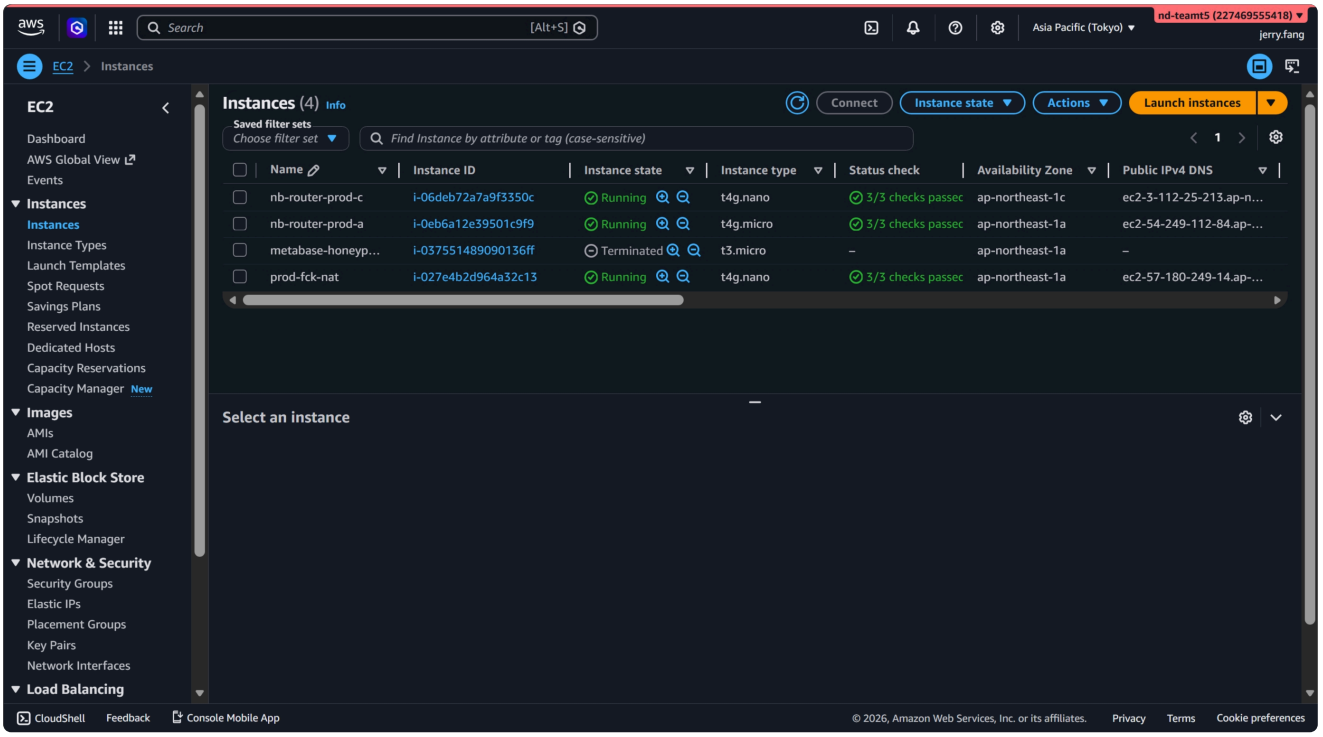
然後就可以連進來了



最後就可以刪掉 EC2 了~



刪除之後還會留在 Instances 中一段時間



可以去檢查 volume 裡面有沒有跟這個台 vps 相關的東西而且狀態是 available ，沒有的話代表有成功刪除

build

開始寫 pulumi

SSM Parameter store

> 我終於搞懂這東西是怎麼運作的

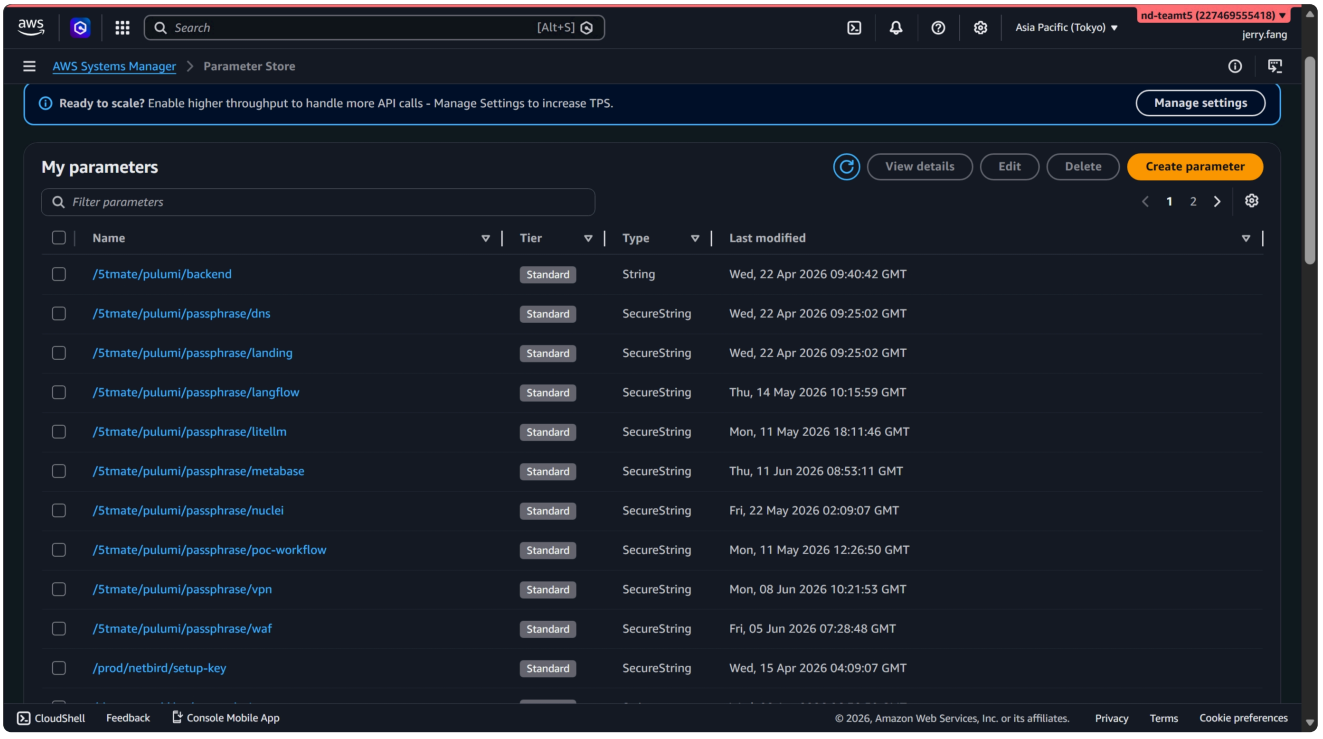
在開始之前我要先建立一個 passphrase

```
aws ssm put-parameter \
    --name /5tmate/pulumi/passphrase/metabase \
    --type SecureString --value "$(openssl rand -base64 32)" \
    --region ap-northeast-1
```

Pulumi state 存在 S3 backend 時有些東西會需要加密保護起來，可以使用 `pulumi config set --secret` 將敏感資料設定成 secrets

被標記成 secrets 的資料會透過被 AWS KMS 加密保護的 Pulumi passphrase (也就是我這邊自己建立的 passphrase) 加上 Pulumi.prod.yaml 裡的 encryptionsalt 產生真正的 encryption key，來加解密這些被標記成 secrets 的資料

現在就可以看到成功建立了 passphrase



Pulumi

寫好基本的設定準備跟環境

把 profile 設定成 pulumi 然後跑腳本讓他去 aws 把 pulumi backend 的位置跟 passphrase 讀出來設成環境變數

然後測試一下

```
# jerry in Jerry ~ > T5 > 5tmate > infra > metabase on git:feat/metabase-honeypot-ec2 [16:57:12]
→ pulumi preview
Previewing update (prod):
     Type                 Name                              Plan
 +   pulumi:pulumi:Stack  5tmate-metabase-honeypot-ec2-prod  create
```

要寫 main 的時候發現 EC2 跟一般 vps 好像有一點點不一樣..
網路環境還可以單獨隔離出來(?
我想要隔離出來不用 default vpc，所以應該會比較複雜一點

Honeypot

要先看一下漏洞的成因跟怎麼打的
NVD - CVE-2023-38646
kh4sh3i/CVE-2023-38646: Metabase Pre-auth RCE (CVE-2023-38646)

初步看起來是 setup-token 外洩
應該是 Metabase 當時有一個前端 bootstrap 用的未登入端點 `GET /api/session/properties`。打了 api 之後會回應，他把 `setup-token` 一起放進這回應裡，要做 honeypot 的話應該要聽這個端點然後回 token

到這邊就下班了~ 明天繼續

小結

今天先用 GUI 手動開一台 EC2 熟悉整個流程（建 key pair、SG 只開自己 IP 的 22 port、看到 IAM instance profile、terminate 之後檢查有沒有殘留的 volume），接著把 Pulumi 在 S3 backend 下怎麼用 SSM Parameter Store 存 passphrase、再搭配 encryptionsalt 加解密 secrets 的機制搞懂了。最後研究 CVE-2023-38646 的成因，確認關鍵是未登入端點 `/api/session/properties` 會外洩 setup-token，所以 honeypot 要能吐出這個 token 才會被判定有洞。明天開始正式用 Pulumi 把隔離的 VPC 跟 Metabase 建起來。

參考資料

- NVD - CVE-2023-38646
- kh4sh3i/CVE-2023-38646: Metabase Pre-auth RCE
- Amazon EC2 key pairs
- AWS Systems Manager Parameter Store
- Pulumi — Secrets